

Bluefield Investment Funds

Customer Information Protection and Incident Response Standard

Document owner	Fund Chief Compliance Officer
Approved by	Board of Trustees
Effective date	November 20, 2025
Version	5.1
Classification	Internal Policy - Fictional Test Document

This fictional document is part of the RegSpan realistic testing corpus. It is written as an ordinary company policy, not as a model answer or legal opinion.

Document Control

Version	Effective date	Summary of change	Approval
1.0	Prior period	Initial program adoption	Management
5.1	November 20, 2025	Updated for amended Regulation S-P and current operating model	Board of Trustees

Policy Overview

Bluefield is a registered fund complex whose transfer agent, administrator, custodian, distributor, and cloud providers perform substantial operational functions.

The sections below describe the firm's approved practices. Department procedures may provide additional implementation detail.

1. Purpose, Scope, and Applicability

Bluefield is a registered fund complex whose transfer agent, administrator, custodian, distributor, and cloud providers perform substantial operational functions.

This document establishes the firm's internal approach to protecting customer information and responding to information-security events. It applies to employees, temporary personnel, contractors, offices, information systems, paper records, and relevant service-provider relationships.

Business units may maintain more detailed procedures, but those procedures may not reduce the protections stated here. Legal and Compliance interpret regulatory obligations and resolve conflicts with other retention, privacy, cybersecurity, or contractual requirements.

2. Definitions

Term	Working definition
Customer information	A record containing nonpublic personal information about a customer of a financial institution, including information handled by or on behalf of the firm and information provided by another financial institution about its customers.
Sensitive customer information	Customer information whose compromise could create a reasonably likely risk of substantial harm or inconvenience to an identified individual.
Customer information system	Information resources and related infrastructure used to collect, process, maintain, use, share, disseminate, or dispose of customer information.
Service provider	A person or entity that receives, maintains, processes, or is permitted access to customer information through services provided directly to the firm.
Incident	Unauthorized access to or use of customer information, or an event reasonably likely to involve such access or use.

3. Roles and Responsibilities

Role	Core responsibilities
Executive sponsor	Provides authority, resources, and escalation support.
Incident Response Lead	Directs triage, response activities, documentation, and closure.
Information Security / Technology	Investigates, contains, restores, and validates systems.
Compliance and Legal	Interprets notice, recordkeeping, regulatory, and law-enforcement obligations.
Business and data owners	Identify affected processes, systems, information, and customers.
Service-provider owner	Coordinates vendor evidence, notices, remediation, and follow-up.
Communications / Customer Service	Prepares approved customer communications and handles inquiries.

4. Customer Information Security Controls

The safeguards program applies to customer information in the firm's possession and customer information handled or maintained on its behalf. It also applies to nonpublic personal information received from another financial institution about that institution's customers. Controls are selected to ensure confidentiality, protect against anticipated threats or hazards, and prevent unauthorized access or use that could result in substantial harm or inconvenience.

- Administrative safeguards: risk assessment, assigned ownership, workforce training, access approval, change management, service-provider oversight, and periodic control review.
- Technical safeguards: multi-factor authentication, least privilege, encryption in transit and at rest where appropriate, endpoint protection, vulnerability management, secure configuration, logging, monitoring, and tested backups.
- Physical safeguards: controlled office and records-room access, visitor management, locked storage, secure transport, clean-desk expectations, and destruction controls for paper and media.

5. Cyber Incident Response Governance

Bluefield Investment Funds maintains this written incident response program as part of its customer information safeguards framework. The program is reasonably designed to detect, respond to, and recover from unauthorized access to or use of customer information. It applies to customer information in paper, electronic, and other forms, including information maintained by service providers on the firm's behalf.

The program begins when monitoring, employee reporting, a service-provider notice, or another reliable source indicates that unauthorized access or use has occurred or is reasonably likely to have occurred. The Incident Response Lead opens a case, assigns severity, preserves relevant records, and coordinates assessment, containment, customer-notice analysis, recovery, and closure.

- Detect: monitor security alerts, access anomalies, customer complaints, lost devices, vendor notices, and misuse reports.
- Respond: investigate, contain, control, communicate, and document decisions.
- Recover: restore approved services, remediate root causes, validate controls and access, and complete a post-incident review.

6. Assessment, Containment, and Control

The response coordinator performs an initial review of the event, identifies the systems believed to be involved, and consults business owners about operational impact. The team may isolate systems, reset credentials, or increase monitoring.

The review records the operational impact, the systems believed to be involved, and the immediate technical steps selected by the response coordinator.

7. Notice to Affected Individuals

Compliance and Legal determine whether notice is required whenever sensitive customer information was, or is reasonably likely to have been, accessed or used without authorization. Notice is presumed unless a reasonable investigation of the facts and circumstances supports a documented determination that the information has not been, and is not reasonably likely to be, used in a manner that would result in substantial harm or inconvenience.

If the firm cannot identify which specific individuals were affected, it notifies all individuals whose sensitive customer information resides in the affected customer information system, except individuals the firm reasonably determines were not subject to unauthorized access or use.

The firm provides or ensures delivery of notice as soon as practicable and no later than 30 calendar days after becoming aware that unauthorized access to or use of customer information occurred or is reasonably likely to have occurred. Investigation and remediation continue in parallel and do not extend the outside deadline.

8. Notice Form and Delivery Standards

Each notice must be clear and conspicuous, written in understandable language, and transmitted by a method reasonably designed to provide actual written notice. Electronic delivery may be used for individuals who have agreed to receive communications electronically.

- a general description of the incident and the type of sensitive customer information involved;
- the incident date, estimated date, or date range, if reasonably possible to determine;
- a telephone number, email address or equivalent method, postal address, and the name of a specific office for questions and assistance;
- for account holders, a recommendation to review account statements and promptly report suspicious activity;
- an explanation of fraud alerts and how to place one;
- a recommendation to obtain credit reports from each nationwide credit reporting company and dispute fraudulent transactions;
- instructions for obtaining free credit reports;
- FTC and [usa.gov](https://www.ftc.gov) identity-theft guidance, encouragement to report identity theft to the FTC, and the applicable FTC website address.

9. Service Provider Oversight

Critical vendors are reviewed before engagement and periodically thereafter. Contracts should address confidentiality, security controls, and prompt incident reporting.

The policy asks providers to report material incidents within five business days after confirming that customer data was affected.

10. Logging and Investigation Records

Teams retain emails and notes relating to significant incidents and provide them to Compliance upon request.

Compliance may request additional messages or system information for significant events.

11. Corrective Action and Post-Incident Review

Recovery begins after the response lead confirms that immediate containment is stable. System owners restore services from approved configurations and backups, reset or reissue credentials, apply patches or configuration changes, and verify that unauthorized access paths have been removed.

Before returning a material customer information system to normal operation, the owner validates security logging, access permissions, data integrity, critical transactions, and required business functions. Remediation items are assigned owners and due dates and remain open until evidence of completion is reviewed.

- document restored systems and data sources;
- perform targeted monitoring for recurrence;
- confirm customer-service and notice obligations remain on track;
- complete a lessons-learned review and update procedures, safeguards, or service-provider requirements;
- obtain closure approval from the incident lead and Compliance.

12. Secure Disposal and Media Handling

Confidential paper is placed in locked shredding bins and destroyed by an approved vendor. Employees may not place customer files in ordinary trash.

The facilities coordinator maintains the shredding schedule and retains vendor service receipts.

13. Books and Records

Compliance maintains true, accurate, and current records demonstrating implementation of the safeguards and disposal program. Records are indexed by incident, requirement, and responsible owner and are available for examination.

- current and prior written safeguards and disposal policies;
- detected unauthorized access or use, including assessment, response, containment, recovery, and closure records;
- notification investigations, determinations, supporting facts, and the basis for any no-notice decision;
- copies of customer notices and delivery records, including notices sent by service providers;
- written documentation from the Attorney General concerning any delay in notice;
- service-provider due diligence, monitoring, breach notices, remediation, contracts, and delegation agreements;
- records of disposal procedures and material destruction activities.

These records are preserved for six years, with the first two years in an easily accessible place; policies in effect during the past six years remain readily accessible. Legal holds and longer requirements supersede the ordinary schedule.

14. National Security and Public Safety Delay

Legal coordinates with appropriate regulators and law-enforcement agencies during significant incidents. Customer communications may be postponed when law enforcement requests a delay or when disclosure could interfere with an active investigation.

Legal records the request and advises management when external communications may resume.

15. Training, Testing, and Review

Personnel receive training appropriate to their roles. Employees are trained to report suspicious access, lost devices, misdirected information, customer complaints suggesting account compromise, and unusual service-provider communications.

The policy owner reviews the document annually and may conduct a tabletop exercise when resources permit.

16. Annual Privacy Notice Administration

Compliance reviews annually whether the firm must deliver privacy notices and coordinates any required mailing or electronic delivery.

Approval

Policy owner	Fund Chief Compliance Officer	Date	November 20, 2025
Approving body	Board of Trustees	Version	5.1